

# API Security Risk Analysis Report

**Target:** <https://jsonplaceholder.typicode.com/posts/1>

**Date:** 2025-01-15

**Analyst:** Security Team

**Classification:** Internal

## 1. Executive Summary

The supplied task report identifies 5 security risks that could impact confidentiality, integrity, and availability. This PDF preserves the supplied sample findings as a project deliverable.

### *Risk Summary*

| Severity | Count | Business Impact                              |
|----------|-------|----------------------------------------------|
| High     | 2     | Potential data breach or unauthorized access |
| Medium   | 3     | Service disruption or information leakage    |
| Low      | 0     | Minor configuration improvement              |

### *Finding 1: Broken Authentication*

**Severity:** High

**Description:** API endpoint is accessible without authentication credentials.

**Business Impact:** Unauthorized users can access sensitive data or functionality.

**Remediation:** Implement OAuth2, JWT, or API Key authentication.

### *Finding 2: Sensitive Data Exposure*

**Severity:** High

**Description:** Potential sensitive data found in response: password, token.

**Business Impact:** Exposure of credentials or PII can lead to account takeover and identity theft.

**Remediation:** Mask sensitive data and use encryption at rest and in transit.

### *Finding 3: Missing Security Headers*

**Severity:** Medium

**Description:** Missing Header: Strict-Transport-Security

**Business Impact:** Vulnerable to SSL stripping attacks.

**Remediation:** Add an appropriate Strict-Transport-Security header.

### *Finding 4: Missing Security Headers*

**Severity:** Medium

**Description:** Missing Header: X-Frame-Options

**Business Impact:** Clickjacking attacks may be possible.

**Remediation:** Add X-Frame-Options: DENY or SAMEORIGIN.

### ***Finding 5: Lack of Rate Limiting***

**Severity:** Medium

**Description:** No rate limiting detected after 10 rapid requests.

**Business Impact:** Attackers can automate requests or perform denial-of-service/brute-force activity.

**Remediation:** Implement rate limiting using an API gateway or middleware.

## **3. Methodology**

Custom Python analyzer using Flask and Requests; tests include unauthenticated access, security headers, rate limiting, sensitive keyword scanning, and malformed input/error leakage.

## **4. Ethical Use**

Only assess APIs you own or are explicitly authorized to test.